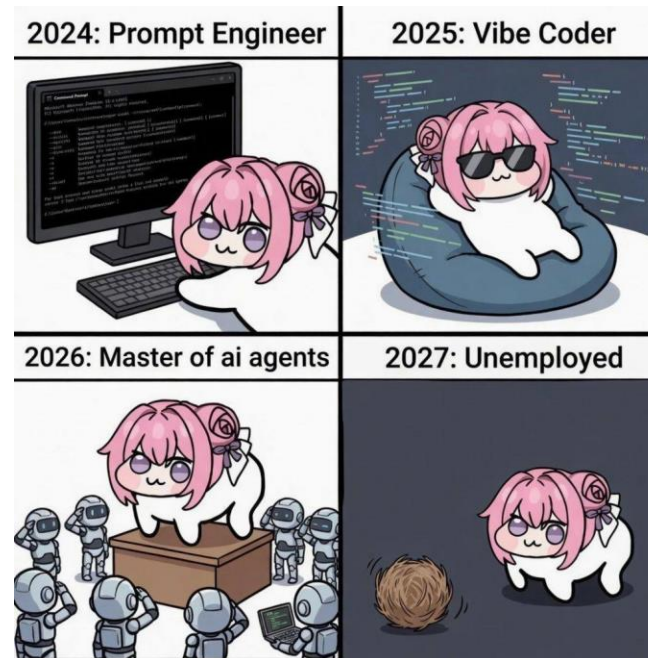


ICT2216:

Secure Software Development



Introduction to second half

Raymond Chan

Second Half...

- Secure Implementation
- Static Code Analysis
- Secure Verification - DAST and Secure Deployment
- Secure Harness engineering

Deliverable 2 details

1. Design Review (if needed)

- Describe any security refinements/changes to your original Deliverable #1 Secure Software Design
- Explain how the security refinements/changes improve your original security design

2. Secure Software Implementation

(Note: A team which can provide evidences with more technical details (e.g. your code snippets (state clearly filenames where the codes can be found), config files, etc.) will score higher than a team which cannot.)

2.1 CI/CD

- Describe the actual CI/CD process and tools adopted by your team during the implementation phase
- GitHub Actions specifying your implemented CI/CD pipeline to be submitted as part of D2
- Evidence of repeated successful auto-triggering of CI/CD process by GitHub Actions throughout implementation phase (a team which starts CI/CD process early will score higher in this component than a team which only tries it nearer the due date or never at all)
- Make sure lecturers have the access to the GitHub Repo for marking

Deliverable 2 details

2.2 GitHub

- List all the directories and files in your team GitHub repository (which will be cloned and given to assigned QA team in Phase D3)
- Explain how your directories and files are organized to facilitate source code review by QA team in D3.
- Class diagrams mapping to your files in GitHub repository
- Evidence of every member contributing to team GitHub repository during implementation phase (a team with all members contributing will score higher in this component than a team with only some members contributing, so your team may wish to make adjustment to your work distribution to ensure all members have the opportunity to participate in all phases of SSD to meet the learning outcomes of this module)
- Evidence of successful auto-triggering of your team GitHub to your AWS VM during implementation phase

Deliverable 2 details

2.3 Secure Implementation of Login

- Sequence diagram of your implemented login process
- How server authentication is implemented?
- If implementing HTTPS, what cipher suites are enabled and why
- If implementing HTTPS, explain where the server private key is stored and whether it's secure
- How key establishment is implemented, and how secret keys are derived
- Cryptographic algorithms used for encrypting communications
- How user authentication is implemented?
- How user passwords are stored, what hash algorithms are used, and how salts are generated if applicable
- How unauthorised access to the stored passwords are prevented

Deliverable 2 details

2.4 Secure implementation of Session Management

- Details on how your application implements session management
- Structure of session tokens or cookies, and how they are generated
- How session tokens or cookies are sent between server and client
- How session tokens or cookies are prevented from modification by users
- How potential session attacks are prevented, e.g. session hijacking, session replay, etc.

Deliverable 2 details

2.5 Secure implementation of Access Control

- Details on how your application implements access control

2.6 Secure coding

- State with evidences (e.g. your code snippets, etc.) all the recommended best practices that your team have followed; e.g. OWASP Top 10 Proactive Controls, etc.

3 Test Automation

- An inventory of all dependencies
- Evidence of implementing dependency check
- Evidence of automated testing that your team has coded and run during the implementation phase

Page Limit: 30 pages (excluding the appendices: marker does not need to read)

Deadline: **Week 10, Thursday, 9th July 9:00 am**

Frozen of the source codes and repo

ALL source codes must be completed and Github repo frozen upon submission of D2.

In D3, your team will be functioning as an internal QA/security team within the same company to verify the app developed by the development team in D3. Thus, your team will be assigned to perform secure software verification on another team to be made known after submission of D2.

More information on D3 will be announced in coming weeks.

Practical Test

- 23rd July during the lab session.
- 2 hours.
- Venue: E2-07-13 and E2-07-14
- 2:00 p.m. – 4:00 p.m.
- Scope: Lab 1 – Lab 10, **open book and open internet.**
- You may use your laptop to conduct the test,
- Please come 15 minutes earlier to ensure you have enough time to setup.
- **Examina will be used for the proctoring the test.**
- **Please test the Examina via the testing link**

Q&A



Solo practical test is always fun